Interview Questions 101:

Disclaimer: These questions asked for DFIR and Incident Response position, and can be helpful for SOC analysts and Threat Hunters.

Introduction

ABRAR HUSSAIN - GCFA

Introduction

Let me start with my educational background. I hold a bachelor's degree in computer science, where I conducted research focused on <malware detection using machine learning algorithms.>
Moving on to my professional career, I've been working in the field of cybersecurity since 2019. I'm currently employed as a Threat Detection and Incident Response Engineer at an MSSP (Managed Security Services Provider).
My core responsibilities include assessing the detection capabilities of various client SOC environments. This involves reviewing and fine-tuning existing use cases in SIEM and SOAR platforms, as well as developing new detection logic based on emerging threats and the MITRE ATT&CK framework.
I'm also an active member of the Incident Response (IR) team, where I participate in investigations during major security incidents. Our role is to identify the root cause, contain the threat, and prepare detailed briefings for senior management.
In addition to IR, I provide annual on-site threat hunting services for clients. These engagements involve proactive threat hunting based on hypotheses, threat intelligence, and anomaly detection.
As part of my role, I also help manage and optimize the SIEM and SOAR) platforms to ensure our detection and response workflows are efficient and scalable.

If I talk about my professional certifications, I hold several industry-recognized credentials including SANS GCFA for forensic analysis, and I recently completed a red teaming certification to broaden my skill set from both a defensive and offensive perspective. I've also pursued other relevant certifications, which are listed in my resume.
Please feel free to ask me any questions—I'd be happy to elaborate on any part of my experience.

Author: abrarkhalid8787@gmail.com

PHISHING ANALYSIS COMPONENTS:

ABRAR HUSSAIN - GCFA

How you extract real sender email?

Ans: Return-Path: Indicates the actual sender's email address, which might differ from the "From" field visible to the recipient.

Received: Provides a trace of the email's route, including timestamps and details of each server or system it passed through. This helps in identifying potential points of compromise or spoofing.

How you differentiate two emails with same title and message body?

Ans: Message-ID: A unique identifier assigned by the email server, useful for tracking and linking related messages.

Authentication Results: Details on whether the email passed authentication checks like SPF (Sender Policy Framework), DKIM (DomainKeys Identified Mail), or DMARC (Domain-based Message Authentication, Reporting, and Conformance). This indicates the email's legitimacy.

X-Originating-IP: Shows the originating IP address of the sender, aiding in geolocation or identifying potential spoofing attempts.

Author: abrarkhalid8787@gmail.com

Subject and Date: While not directly related to the email's path, they provide context and aid in correlating with other information during investigations.

Content-Type: Indicates the format of the email and any attachments, which can be crucial in assessing potential threats like malicious payloads.

People Will Test your Knowledge on Authentication Protocols!

1. SPF(Sender Policy Framework)

It works by checking if the sender's IP address is authorized to send emails for a specific domain.The domain owner publishes SPF records in their DNS settings, listing authorized sending servers.

When an email is received, the recipient's server checks the SPF record to verify if the sender's IP is authorized. If the check fails, it suggests the email might be spoofed or unauthorized.

2. DomainKeys Identified Mail (DKIM):

DKIM is an email authentication method that adds a digital signature to an email's header using public-key cryptography. This signature is generated by the sending mail server using a private key associated with the sender's domain and is stored as a public key in the sender's DNS records.

When the email is received, the recipient's server uses the public key to verify the signature. If the signature is valid, it confirms that the email was not altered during transit and that it originated from the stated domain.

3. Domain-based Message Authentication, Reporting, and Conformance (DMARC):

DMARC is a policy framework that builds upon SPF and DKIM to provide further email authentication and reporting capabilities. It allows senders to specify policies for SPF and

ABRAR HUSSAIN - GCFA

DKIM alignment. DMARC instructs the recipient's server on how to handle emails that fail SPF and DKIM checks. It can specify actions such as rejecting, quarantining, or delivering the emails while also providing feedback to the sender about failed authentication attempts through aggregate and forensic reports.

==========

You received an email attachment that have three files with extensions .doc, docx and docm, which poses macros in it?

Ans: Word Macro-Enabled Document (.docm) :

The XML-based document format that preserves VBA macro code. VBA macros run in Word 2016 for Mac and Word for Mac 2011, but they do not run in Word 2008.

==========

OWASP TOP 10 Detection!

1. **Injection: SQL Injection: To detect SQL injection from logs:**

Look for unexpected SQL keywords or symbols in logs, such as "UNION," "SELECT," "DROP," "INSERT," etc., especially in user inputs or URL parameters.

Monitor for log entries with unusual or malformed SQL queries, especially those containing additional queries concatenated through input fields.

Watch out for errors or exceptions related to SQL queries that indicate attempts to manipulate database queries, like syntax errors or unexpected query results.

Analyze logs for high rates of SQL errors or warnings, which could signal injection attempts.

ABRAR HUSSAIN - GCFA

Author: abrarkhalid8787@gmail.com

2. Cross-Site Scripting (XSS): Monitor web server logs and application logs for signs of XSS attacks

HTTP Request Logs:

Analyze HTTP request logs for unusual or unexpected input in parameters, especially in URL query strings, form fields, or cookie data.

Look for entries containing JavaScript code or HTML tags in parameters or payloads submitted to the server.

Web Server Logs:

Monitor web server logs for requests that generate responses containing unexpected JavaScript execution or HTML tags in the response body.

Look for anomalies in response sizes or content-types that might indicate script injections or manipulated content.

Application Logs:

Scan application logs for error messages or exceptions related to input validation failures or attempts to process unexpected script-like content.

Look for entries indicating the encoding or decoding of input data, as attackers might use encoding techniques to bypass filters.

Unusual User Input:

Identify log entries where user input gets reflected back in the response without proper sanitization or encoding, which could indicate a potential XSS vulnerability.

Monitor logs for entries where user-provided data is used in JavaScript contexts or embedded within HTML content without appropriate escaping.

2.1 DOM-based XSS:

For JavaScript-heavy applications, watch for logs indicating manipulation of the DOM (Document Object Model) with potentially malicious scripts.

ABRAR HUSSAIN - GCFA

Author: abrarkhalid8787@gmail.com

3. Broken Access Control: Detect unauthorized access attempts or unusual access patterns to restricted resources.

HTTP Status Codes:

Monitor for HTTP status codes such as 401 (Unauthorized), 403 (Forbidden), or 404 (Not Found) that might indicate failed attempts to access restricted resources.

Watch for unexpected or unauthorized 200 (OK) status codes for resources that should typically return an error for unauthorized access.

4. Security Misconfigurations:

Unused Services and Open Ports:

Analyze system or network logs to identify services or ports not typically used or unnecessary for the system's operation.

Look for logs indicating services or ports that were accessed or activated unexpectedly, potentially indicating attempts to exploit unnecessary open services.

Configuration Change Logs:

Analyze logs related to configuration changes in systems, applications, or network devices. Look for entries indicating alterations to security settings or configurations.

Track logs that report modifications to access controls, permissions, or other security-related settings.

==========

Define SSRF - Server Side Request Forgery?

Sure! An SSRF (Server-Side Request Forgery) attack is a type of cyber attack where a hacker tricks a website or a server into making requests on their behalf. Imagine you're asking someone to fetch something for you from a store. In this case, the hacker is pretending to be someone else to get the website or server to give them information or do things they're not supposed to.

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GCFA

But in a Server-Side Request Forgery (SSRF) attack, a sneaky trickster convinces the website to let them send requests to other places, like secret rooms, that they're not supposed to access. It's like your friend getting into rooms they're not allowed to enter and bringing back things that might not be safe or allowed.

==========

How credential dumping performed?

reg save HKLM\SAM sam_backup.hiv

john --format=NT sam_backup.hiv

hashcat -m 1000 -a 0 sam_backup.hiv <wordlist_file>

==========

SYSTEM PROCESSES

what happen when windows os started (define the background process)? (Recommnded to review SANS HUNT EVIL POSTER)

1. Boot Sequence:

   Power-On Self Test (POST): Hardware components are tested to ensure they're functioning correctly.

   BIOS/UEFI Initialization: Basic Input/Output System (BIOS) or Unified Extensible Firmware Interface (UEFI) performs hardware checks and loads the bootloader.

2. Bootloader:

   Boot Manager (e.g., Windows Boot Manager): Loads and executes the Windows bootloader (e.g., Winload.exe).

   Boot Configuration Data (BCD): Contains boot options and settings for the OS.

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GOFA

3. Kernel Initialization:

Windows Kernel (NTOSKRNL.EXE): Loads essential system drivers and initializes critical components.

4. Session Manager:

Session Manager (SMSS.EXE): Starts the user-mode part of the Windows subsystem and creates the environment for the user.

5. WinLogon:

WinLogon (WINLOGON.EXE): Manages the secure attention sequence (Ctrl+Alt+Delete), user logon, and secure desktop.

6. Service Control Manager (SCM):

Service Control Manager (SERVICES.EXE): Starts system services defined in the registry, managing essential background processes.

7. User Environment Initialization:

Local Security Authority Subsystem Service (LSASS.EXE): Responsible for security policy enforcement, user authentication, and Active Directory services.

Userinit (USERINIT.EXE): Loads user-specific settings, runs logon scripts, and starts the user shell (e.g., Explorer.exe).

8. Explorer.exe:

Windows Explorer (EXPLORER.EXE): The shell for the Windows graphical user interface (GUI) that provides the desktop environment.

9. Networking and Services:

Network Services: Services related to networking, such as DHCP, DNS, and network protocols, start to enable network connectivity.

Additional Services: Other essential system and background services, like antivirus, firewall, and system monitoring services, may start depending on the system configuration.

10. User Session Initialization:

ABRAR HUSSAIN - GCFA

Author: abrarkhalid8787@gmail.com

User Profile Load: Loads user-specific settings, desktop preferences, and user applications defined for auto-start.

11. System Ready:

User Login: The system is ready for user login and interaction.

==========

DLL ATTACKS

Define DLL Search Order Hijacking:?

Description: DLL search order hijacking, also known as DLL planting or DLL preloading, involves manipulating the search order that Windows uses to locate and load DLLs for an application.

Exploitation: Attackers exploit vulnerable applications that load DLLs using only the filename, without specifying the full path. They place a malicious DLL with the same name as the one the application is expected to load in a directory that the application searches during the DLL loading process.

Execution: When the application is executed and attempts to load the DLL, it first searches the current directory or other specified directories, and if it finds the malicious DLL there, it loads the attacker's code instead of the legitimate DLL.

Define DLL Side-Loading:?

Description: DLL side-loading is a technique where attackers take advantage of legitimate applications that improperly load DLLs, allowing them to substitute a legitimate DLL with a malicious one.

Exploitation: Similar to DLL search order hijacking, it relies on vulnerable applications that don't specify the full path for loading required DLLs. Attackers place a malicious DLL alongside the application (in the current working directory or a directory specified in the system's PATH variable).

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GCFA

Execution: When the application is launched, it loads the DLL without specifying the full path, inadvertently loading the attacker's malicious DLL instead of the intended legitimate one.

DEFINE Dll Injection:?

Ans: The attacking process can allocate space in a running process, write the DLL file to load in the new space, and then create a new thread to load the DLL into the running process using the Windows VirtualAllocEx() and CreateRemoteThread() function calls.

Detecting DLL hijacking: ?

Sysmon Event ID 7, ImageLoad, logs any DLLs that are loaded into a processes memory.

detection if the value of the ImageLoadedfield on Sysmon Event ID 7 is in this selection list of DLLs AND if the image path does not begin with C:\Windows\WinSxS or C:\Windows\System32

==========

SIEM Usecase

Explain the Use-Case Rule for DNS Tunneling Detection on SIEM?

1. **Excessive Subdomains or Lengthy DNS Queries:**

Condition: Detect DNS queries with an abnormally high number of subdomains or excessively long domain names.

Rationale: DNS tunneling often involves encoding data into subdomains or using long domain names to bypass detection.

2. **Unusual DNS Query Types or Non-Standard Ports:**

Condition: Detect DNS queries using non-standard DNS query types (e.g., TXT, AAAA, CNAME) or queries on unusual ports (other than UDP/53).

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GCFA

Rationale: Attackers might use non-standard DNS query types or ports for tunneling to avoid detection.

1. **High Query Frequency or Unusual Time Patterns:**

Condition: Identify a high frequency of DNS queries from a single source within a short time frame or unusual patterns of DNS traffic during off-hours.

Rationale: DNS tunneling might involve an abnormal volume of queries sent in rapid succession or at irregular times.

Define WinRM?

stands for Windows Remote Management, which is a management protocol used in Windows operating systems to enable remote management and execution of commands on remote machines. It's part of the Windows Management Framework and is built on the WS-Management protocol.

WinRM Components:

WinRM Service (WinRM):

The service responsible for handling incoming WinRM requests and managing communication between client and server.

WinRM Listener:

A listener is configured to listen for incoming WinRM requests. It defines the protocol (HTTP/HTTPS), ports, and authentication methods.

==========

Threat Hunting Questions!

Prepare one of the stories of your hunt!

Read the blogs and advisories!

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GCFA

What is Threat Hunting?
Its a form of an Active Defense and a Proactive Strategy. Instead of waiting for an Alam to trigger, the Proactive Threat Hunt Teams actively hunt for the evil in their Organization based on the Threat Informed Intel.

Threat Informed Intel?
Threat-Informed Intelligence means using real information about how hackers attack to help protect against them. Instead of guessing what might happen, you use facts about real attacks — like what tools hackers use, how they break in, and what they go after — to

KPI and Metrics for the Threat Hunting Teams?

1. Dwell Time: It's the time an attacker has remained undetected within the network.

2. Break Out Time: It is the Time an intruder takes to begin moving laterally once they have an initial foothold in the network.

3. Detection Rules created via Threat Hunt Activity:

4. Threat Intel Source and Tools Check:
Is the threat intel you're receiving too generic?
Are your hunts based only on indicators at the lowest level of the Pyramid of Pain (e.g., IPs, hashes), with little to no alignment to MITRE ATT&CK TTPs? Are you getting any relevant Tactical Threat Hunt?
Is your intelligence so superficial, the absence of a dedicated threat intelligence analyst on your team?

5. Visibility Gaps: The Cloud-hosted VMs are missing EDR solution to give you telemetry.
Horizontal gaps: are hosts missing all the SOC tools or a particular department you have no visibility.
Veritical Gap: is you have a Host sending a Logs but may be Missing an EDR or may be Both are there but Sysmon is missing from the Host or you are not getting the netflow or may be an AV is missing on the Host.

6. Security Misconfigurations: Outdated versions prone to newly discovered CVEs, Credentials were found in plaintext for authentication.

7. Lack of Tools to Perform the Threat Hunt: DNS hunting required DNS logs and dedicated DNS security solution to hunt down the evil activity.

8. Valuation of An EDR: Lets take a scenario that you are hunting for Unsigned Binaries or unsigned Drivers in your Organization and you found out that your EDR tool doesn't have the ability to track the Signature and certificates of a Binary.

9. Tunning False Positive Ratio of Security Tools: Your Hunt lead to Tune a Rule or tune a Security Tool for the SOC.
10. Valuation of Incident Response Teams:
You figured out the IR Team responded to the attack previously but failed to incorporate proper "Scoping and Containment" into account, or it's a leftover from a third-party pentesting company that engaged in a Red Teaming exercise, and those leftovers were not removed.

Source: https://medium.com/@CyberAxe/kpis-and-metrics-for-threat-hunting-bddaf7b244a6

Explain Hypotheses:

The cyber threat hunting process typically begins with the development of a threat hypothesis based on a range of different factors. This may include previously known threats, vulnerabilities identified within the system, or threat intelligence data. The hypothesis development is crucial, as it enables analysts to identify patterns and anomalies that may indicate potential threats.

1. Hunting for process command line artifacts of service creation

“Threat actors might use command line utilities to create a service”. Usually we consider utilities such as sc.exe with a specific parameter (namely, create), so our initial query might look like this:

event_type: "Process creation"

AND Payload.ImageFileName: "*\\sc.exe" AND

Payload.Commandline: "* create *"

2. Hunting for registry artifacts of service creation

“Threat actors might create a Windows service using any tool, but we will still be able to see changes in the corresponding registry keys.”

event_type: "Registry key value creation or modification"

AND Payload.KeyName: "*\\services*"

AND Payload.Value: ["ImagePath", "ServiceDll"]

The ImagePath value contains a path to an executable file, and ServiceDll contains a path to a DLL file (if DLL is launched as a service).

The main difference compared with EXE file as a service is that the threat actors must perform an additional action (create a service + assign a DLL file to this service separately). Overall, DLL as a service execution requires execution in a context of specific process which is svchost.exe,

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - GCFA

We will focus on .exe files being executed as services and on .dll files being loaded in the context of a service process.

“There will be a suspicious process executed as a service”.

Simply put, we expect to observe a process being spawned by a services.exe process, the well-known “father of all services” in Windows OS. In such cases, the initial EDR query might look like this:

==========

==========

ABRAR HUSSAIN - GCFA

What happen when user typed the URL on browser? (Explain the background process)

Domain Name System (DNS) Resolution:

Now, the browser needs to find the actual numerical IP address associated with the domain name (like www.example.com) because computers communicate using IP addresses, not human-readable domain names.

The browser first checks its cache (a temporary storage) to see if it already knows the IP address for that domain. If it finds the IP there, it skips the rest of the process and goes directly to that IP.

If not in the cache, the browser sends a request to the DNS resolver. This resolver might be your internet service provider's (ISP) server or another server specified in your network settings.

Author: abrarkhalid8787@gmail.com

The DNS resolver then checks its own cache. If it doesn't have the IP address, it forwards the request to the root server.

The root server doesn't directly provide the IP address but directs the resolver to the appropriate Top-Level Domain (TLD) server responsible for the domain's extension (.com, .net, etc.).

The TLD server then directs the resolver to the authoritative DNS server for the specific domain (e.g., example.com). This server holds the precise IP address associated with the domain.

Finally, the authoritative DNS server sends the IP address back to the resolver, which forwards it to your browser.

==========

Prepare Yourself for following topics:

5 Artifacts for Process Execution (Go Through SANS 500 Poster)

PsExec scenario (Go through SANS HUNT EVIL POSTER)

Ransomware Scenario (Look Through MITRE and prepare an story from initial access to Exfiltration,

Just like this wonderful story from CISA about Iranian Hackers:
https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-264a)

Negotiate Salary:

Based on my experience, skills, and the value I can bring to the role, I was aiming for a salary in the range of [desired salary range]. I'm open to discussing and finding a mutually beneficial arrangement that aligns with the responsibilities and expectations of this position."

ABRAR HUSSAIN - GCFA

Author: abrarkhalid8787@gmail.com

Recent Questions:

Last major incident?
Ans: Prepare the brief for real world incident you come across, just explain your role in that incident.

Word document analysis
Malware Analysis:
ISO file analysis & IOCs extraction!?
Word document analysis ?
Ans: At first glance, i will check the extension of the file, either its docm, xlsm file, then Get the suspected attachments in sandbox environment /deep sheep laptop,
Start from static analysis wihtout running the attachment and understand the content inside , the first step would be calculate the hash and search across the TI platforms, then using tools like floss or strings to get the strings in the attachements and also use the oledump tools from dedier steven suite and olevba for potential malicious embeded VBA code.

Moving further to dynamic analysis by executing the attachements in sandbox environment and check what's the behaviour like what process the attachment create, either its making any outbound connection, where this attachment writes, and registry modification recorded.

Web App protection approach!?

TGT ?
TICKET Issuer name? KDC key distribution center
Kerberos vs NTLM?
TGT port? 88 port

What is the Yara rule?

Volatility weakness?

AD Questions:
Domain Trust
RDC PDC difference?
Forest Tree
PTH use-case in SIEM:?
Pass-the-Hash Attack:
and Logsource Microsoft Windows Security Event Log
and event ID: 4624
Logon process: Seclogo
Logon type: 9
Authentication Package = Negotiate
Memory Analysis Questions:
Process Hollowing SIEM use-case?
OSINT example!
Phishing OSINT ?
Compromised system analysis without any third party tool. ?
Password spray attack ?
What is sysmon,?
How to reduce false positives?
Qradar majester service ?

Author: abrarkhalid8787@gmail.com

ABRAR HUSSAIN - CCFA

Recent Questions:

-DNS resolution
-Proxy vs Firewall
-EDR vs SYSMON
-pTH VS PTT
-Netsh Usage
-Zeek
-Sigma signature
-how many types of logs in Windows

Security Analyst I - Questions

What is the difference between a security incident and a security event?
Are you familiar with indicators of compromise (IOC)?
How do you handle a situation where you receive an event with a lack of information?
If a SIEM tool alerts you to a specific executable, but it doesn't provide the exact path, and you suspect it matches a known threat but lack sufficient information, what would you do in such a scenario?
How do you approach hyper-analysis in security investigations? Are you familiar with this concept?
If you detect an internal IP creating malicious activity but have limited information, how would you investigate this issue?
Are you familiar with tools like OpenDNS, Microsoft Management Console, and DHCP tables?
What is the purpose of an incident response plan, and what phases generally make up this plan?
How do you identify and classify a security threat as low, medium, or high? Can you provide examples of incidents in each classification?
Are you familiar with a playbook in security operations? What is its purpose?
Can you share your experience with using a playbook in your security operations?
What is the most significant security-based incident you have been involved in, and what role did you play in handling it?
Can you describe your experience with vulnerability management and your work with tools like Qualys?
What tasks are you responsible for when using Qualys?
Do you have experience with business email compromise (BEC) incidents and responding to them, particularly in an Office 365 (O365) environment?

ABRAR HUSSAIN, GCFA

Author: abrarkhalid8787@gmail.com

Ab Hussain 101